

CURRENT STATE — what actually runs today

UPS Reprice Platform · sandyliu3056/ups-reprice-web · read off index.html, auth-config.js and supabase/*.sql as committed

LOCAL_MODE = true

● in use ○ present but idle ✗ blocked △ attention

1 · DELIVERY

GitHub repository

branch: main
pre-commit hook blocks keys

Static host

Vercel · Cloudflare Pages · Netlify · Pages
no build step — files are served as-is

4 files delivered to the browser

index.html · auth-config.js
supabase-js-2.112.3.js · xlsx-0.18.5.full.min.js

In the repo, NOT served

authconfig.js — dead, nothing loads it
supabase/*.sql · functions/ · *.py (desktop)

① page load

2 · THE USER'S BROWSER — no server involved

Loaded assets

index.html

UI + the entire pricing engine
~602 KB, a single file
tabs: Import · Surcharge · Size ·
Channels · Demand · History ·
Codes · Dashboard · Settings · Admin

supabase-js-2.112.3.js

loaded, but only used for RPC

xlsx-0.18.5.full.min.js

reads and writes Excel

auth-config.js

{ url, anonKey }

△ no authMode key, therefore
LOCAL_MODE = true

Sign-in — local account mode

① user types a username + password
② `h = sha256(username + ":" + password)`
③ compare with `LOCAL_ACCOUNTS[]` — an array literal inside index.html
④ on a match, build the identity:
`ME.id = "local::" + username`
`ME.role = "admin" | "user"`
`ME.sync = sha256("cfg-sync::" + username + ":" + password)`
⑤ session → `sessionStorage`; `localStorage` only if "keep me signed in" is ticked
`AUTH = null`
no Supabase auth client is ever built
`SYNC = anon client`, RPC calls only
△ the password hashes ship with the page
△ adding or removing a user = edit + redeploy

Pricing pipeline — in memory

INPUT (never uploaded)

UPS invoice — `xlsx / xls / csv`
a headerless CSV is detected
Contract rate tables — one file per service, or several at once

PROCESS — browser memory

parse → DIM weight → base rate →
surcharges (AHS / LPS / demand) →
fuel → channel margin

OUTPUT — written by `xlsx.js`

Client report.xlsx
Internal statement.xlsx
cost, profit and margin

✓ invoice files never leave
this machine

Per-account storage, this machine

localStorage

`ups_reprice_cfg::<ME.id>`
`...hist::<ME.id>` period index
`...histinv::<ME.id>` invoice list
`ups_reprice_log` activity log

IndexedDB

`<db>::<ME.id>` shipment detail

sessionStorage

`ups_reprice_local_session`

△ every key is prefixed with `ME.id`,
which today is `"local::<username>"`.
Change the identity and the app
reads as empty — the data is still
there, under the old prefix.
Same-machine user switching relies on it.

3 · SUPABASE PROJECT — reached only through RPC today

Auth ○ NOT USED

`auth.users` may already hold accounts, but
nothing in the app ever signs in through it.

- the AUTH client is never constructed
- `signInWithPassword()` is never called
- `record_login()` is never called
- `app_metadata.role` is never read
- no session is issued or refreshed

△ public sign-ups may still be enabled
in the dashboard. Harmless while Auth
is unused — not harmless the moment
you switch. Turn it off first.

Postgres + Row Level Security

local_settings ● IN USE

RLS ON with ZERO policies — the anon key
cannot read, write or even list this table
↳ `local_settings_get(k) / _put(k, cfg, name)`
`SECURITY DEFINER · k must match`
`^[0-9a-f]{64}$` — `k` is `ME.sync`

local_history ● IN USE

↳ `local_history_list / _get / _put / _del`
gzip'd in the browser · add-or-replace only:
clearing one machine never deletes the copy

login_history ○ profiles ○ user_settings ○

created by the SQL files — no code path in
this mode ever touches them

Edge Functions

ups-address ● IN USE (if deployed)

`POST { name, address, city, state, postal, country } → { class: R | C | U }`
Holds `UPS_CLIENT_ID / UPS_CLIENT_SECRET` as
function secrets — the browser never sees them
Endpoint is pasted into the Invoice History tab

admin-users ✗ UNREACHABLE

Needs a Supabase access token to prove the
caller is an admin. In local mode there is no
token, so the Admin tab can only list the
hard-coded accounts — it cannot create one.

✓ the service_role key lives only here —
it is never delivered to a browser

② settings + history sync · RPC keyed by `ME.sync`

③ address lookup

✗ admin-users unreachable

TARGET STATE — Supabase Auth switched on

Green = already written, needs configuration only. Orange = still has to be built. Everything else is unchanged from the current state.

authMode: "supabase"

● works once switched ▲ must be built △ attention

1 · DELIVERY

GitHub repository

branch: main
unchanged

Static host

unchanged — still serves 4 files
Site URL registered with Supabase

The only file that changes

auth-config.js → { authMode: "supabase", url, anonKey }
index.html is not edited at all — the code is already there

Deployed to Supabase, not the site

schema.sql · login_history.sql · 2 functions
▲ delete authconfig.js (dead file)

2 · THE USER'S BROWSER — identity now comes from outside

Loaded assets

index.html

byte-for-byte the same file
both sign-in paths already live in it;
one line of config picks between them

supabase-js-2.112.3.js

now doing real work: auth + RLS calls

xlsx-0.18.5.full.min.js

unchanged

auth-config.js

```
{ authMode: "supabase",  
  url, anonKey }
```

✓ still only public values here

the service_role key never appears
the pre-commit hook keeps it that way

Sign-in — Supabase Auth

- ① user types a username + password
- ② loginEmail(): no "@" in the input, so
append @ups-reprice.invalid
- ③ signInWithPassword({ email, password })
- ④ Supabase returns a session:
access_token — JWT, auto-refreshed
app_metadata.role → "admin" | "user"
user_metadata.display_name
- ⑤ ME.id = the account's UUID
- ⑥ AUTH.rpc("record_login", { p_user_agent })

AUTH = Supabase client, session persisted
SYNC = AUTH

one connection, one identity — the
sync-key locker is no longer used

- ✓ no password or hash ships with the page
- ✓ add or disable a user without redeploying

Pricing pipeline — unchanged

INPUT (never uploaded)

UPS invoice — xlsx / xls / csv
Contract rate tables

PROCESS — browser memory

parse → DIM weight → base rate →
surcharges → fuel → channel margin

OUTPUT — written by xlsx.js

Client report.xlsx
Internal statement.xlsx

- ✓ nothing about rating moves to the cloud. Supabase never sees an invoice line or a contract rate.

This is the part worth protecting,
and the switch does not touch it.

Per-account storage — the one hazard

The same keys as today, but the prefix
is a different value:

before local::sandy...@gmail.com
after 3f7a91c4-... (UUID)

▲ GAP 1 — claim the legacy data

On first Supabase sign-in: if the new
prefix is empty and this machine holds
local::<username> data, adopt it —
settings, period index, invoice list
and the IndexedDB database.
index.html already names this as unwritten.

Interim workaround, no code needed:

export the settings before switching,
import them after the first sign-in.

Test on a preview URL before production.

3 · SUPABASE PROJECT — now the source of identity

Auth ● ACTIVE

Email provider ON

Public sign-ups OFF ← do this first

Accounts created in the dashboard with
"Auto Confirm User" ticked

auth.users

raw_app_meta_data.role = admin | user
writable by service_role / SQL only —
this is why the role is trusted
raw_user_meta_data.display_name
user-editable, therefore never a role

▲ @ups-reprice.invalid accounts cannot
receive a password-reset mail. Use a
real address where that matters.

Postgres + Row Level Security

user_settings ● one row per account

upsert / select where user_id = auth.uid()
holds that account's contract rate configuration

profiles ● display copy only

kept in step by a trigger on auth.users; the role
column here is a copy, never the authority

login_history ● admin-readable

↳ record_login(p_user_agent)
SECURITY DEFINER — user id, email and time are
taken from the verified JWT, not from the request.
Browsers cannot write to the table at all.

▲ GAP 2 — invoice history has no cloud sync here

Edge Functions

admin-users ● ACTIVE

list · create · change role · delete
Verifies the caller's JWT and requires
app_metadata.role = "admin"
→ anything else gets 403 before the body is read
▲ turn OFF "Enforce JWT verification" —
the function runs its own, stricter check

ups-address ● ACTIVE

unchanged from today

▲ WORK REMAINING

- 1 · claim legacy per-machine data on first sign-in
- 2 · invoice-history sync for Supabase mode
- 3 · delete the dead authconfig.js

Current → Target: what actually changes

One config line moves the app from the left column to the middle. The right column is what that line does **not** do for you.

Area	Current state	Target state	Work required
Mode switch	<code>auth-config.js</code> has no <code>authMode</code> , so <code>LOCAL_MODE = true</code>	<code>authMode: "supabase"</code> present; both code paths already exist in <code>index.html</code>	Edit one file, redeploy. Reversible by deleting the line.
Where passwords live	SHA-256 hashes in <code>LOCAL_ACCOUNTS[]</code> , shipped inside the page. Old plaintext values remain in git history.	Supabase Auth holds them. Nothing password-shaped is delivered to the browser.	Create each account in the dashboard with a new password. Never reuse one that was ever in the repo.
Who can sign in	Only the two hard-coded accounts. Public sign-up setting is irrelevant because Auth is unused.	Only accounts the owner creates — provided public sign-ups are disabled .	Authentication → Providers → Email → turn sign-ups OFF. Do this before switching, not after.
Account identity (ME.id)	<code>"local::<username>"</code>	The account UUID from Supabase	GAP 1 — every localStorage key and the IndexedDB name are prefixed with this. Nothing migrates them yet.
Adding / removing a user	Edit <code>index.html</code> , commit, redeploy. The person keeps access until the deploy lands.	Dashboard, or the Admin tab in the app. Effective as soon as their token expires.	Deploy <code>admin-users</code> for the in-app route; the dashboard route needs nothing.
Roles	<code>role</code> field in the hard-coded array — visible to anyone reading the page	<code>app_metadata.role</code> , carried in the JWT. Users cannot edit that field.	One <code>update auth.users</code> statement per admin. Sign out and in again — the role rides in the token.
Session	A JSON blob in sessionStorage (or localStorage if "keep me signed in")	Supabase session with an auto-refreshed access token	Nothing. Handled by the client library.
Rate settings sync	<code>local_settings</code> via two SECURITY DEFINER RPCs, keyed by <code>sha256("cfg-sync::"+user+"::"+pw)</code>	<code>user_settings</code> , one row per account, RLS on <code>auth.uid()</code>	Run <code>supabase/schema.sql</code> . Note: settings already parked under a sync key do not carry over — save once after switching.
Invoice history sync	<code>local_history</code> RPCs — works, gzip'd, add-or-replace	Nothing. <code>histPush/histPull</code> return early unless <code>LOCAL_MODE</code> .	GAP 2 — a table keyed by <code>auth.uid()</code> plus RLS, mirroring what <code>local_history</code> already does. This is a regression if not built.
Login history	Local activity log — this browser only	<code>login_history</code> , written by <code>record_login()</code> ; identity and timestamp derived server-side from the JWT; admin-only read policy	Run <code>supabase/login_history.sql</code> . Failed attempts and IP addresses stay in Supabase's own auth logs.
Admin tab	Read-only list of the hard-coded accounts	Full account management through <code>admin-users</code>	Deploy the function, then turn OFF "Enforce JWT verification" on it — the function authenticates callers itself, more strictly than the platform toggle.
Address lookup	<code>ups-address</code> Edge Function — UPS keys held as function secrets	Unchanged	Nothing.
Pricing engine	Runs entirely in the browser. Invoices and contract rates never reach Supabase — before or after the switch.		Nothing. This is the part the switch deliberately does not touch.
Dead config file	<code>authconfig.js</code> exists and is loaded by nothing. Editing it has no effect.	Gone.	GAP 3 — delete it, so there is one config file and one place to look.

Order of operations

1. Export current settings to a file.
2. Turn public sign-ups OFF.
3. Create accounts — tick **Auto Confirm User**.
4. Set `app_metadata.role` for the admin.
5. Run `schema.sql` and `login_history.sql`.
6. Deploy both Edge Functions; disable enforced JWT on `admin-users`.
7. Set Site URL and Redirect URLs.
8. Switch `authMode` on a preview URL first.
9. Sign in, re-import settings, verify the Admin tab.
10. Promote to production.

How to tell it worked

- The BUILD timestamp in the header moved forward — otherwise you are looking at a cached page, not a broken switch.
- Signing in with a deliberately wrong password fails *at Supabase*, not instantly in the page.
- The Admin tab appears for the admin account and **not** for a normal one.
- The Admin tab lists real accounts — that proves `admin-users` is reachable.
- A second sign-in shows up in `login_history`.

Rollback

Delete the `authMode` line from `auth-config.js` and redeploy. The app returns to local-account mode and the old per-machine data — still under its `local::` prefix — becomes visible again.

Nothing written to Supabase during the trial is destroyed by rolling back; the two modes read different tables.

The one-way part is the accounts and passwords you created — those stay in Supabase, unused, until you switch again.